

SUNIL SODHI

AI Governance & Risk • LLM Security • Model Validation

Jersey City, NJ • NYC Metro | 949-545-4237 | sunilksodhi@gmail.com
linkedin.com/in/sunil-sodhi-30901a81 | github.com/sharingkapotter | portfolio-five-phi-1x7vlnfbzs.vercel.app

PROFESSIONAL SUMMARY

AI governance and risk practitioner with 20 years of independent validation on regulated platforms across insurance, banking, healthcare and retail. I assess AI systems against the NIST AI Risk Management Framework, ISO/IEC 42001 and the EU AI Act — risk-tier classification, control gap analysis, AI risk registers and costed remediation roadmaps — and run adversarial LLM security assessments mapped to the OWASP Top 10 for LLM Applications and MITRE ATLAS — and I build the tooling that enforces those controls in a pipeline rather than stopping at policy.

FRAMEWORKS & CORE COMPETENCIES

AI Governance & Risk NIST AI RMF • NIST AI 600-1 (GenAI Profile) • ISO/IEC 42001 • EU AI Act • Risk-Tier Classification • AI Risk Register • Control Gap Analysis • Model Risk Management • Model Validation • Responsible AI • Audit Readiness

AI & LLM Security OWASP Top 10 for LLM Applications • OWASP Top 10 for Agentic Applications • MITRE ATLAS • Google SAIF • AI Red Teaming • Prompt Injection • Indirect Injection • Jailbreak Testing • Adversarial ML (FGSM, PGD) • Bias & Fairness Testing

Security & Compliance ISO/IEC 27001 • NIST 800-53 • ISO 9000 • OWASP Top 10 • OWASP API Security Top 10 • Threat Modeling • SAST • SCA • Container Scanning • Secure SDLC • DevSecOps • Controls Testing

Engineering Python • C# • SQL • GitHub Actions • Azure DevOps • Docker • Semgrep • Trivy • Nexus IQ • pytest • Reqnroll/SpecFlow • Playwright • RestSharp • Kafka • Datadog APM/RUM • JMeter • PostgreSQL • AWS Redshift

Leadership Team Leadership (onshore & offshore) • Stakeholder Management • Executive & Board-Level Risk Reporting • Release Readiness and Go/No-Go Decisioning • Consulting

PROFESSIONAL EXPERIENCE

Sr. Consultant — Quality, Assurance & Application Security <i>Contract • Client confidential (Insurance & Retail)</i>	Feb 2026 – Present Remote
• Sole quality and assurance lead on enterprise platforms at a top-five US auto insurer and a Fortune 500 grocery retailer — established the quality engineering function end to end across strategy, process, standards and the full SDLC. • Led application security assessment across web and API surfaces against the OWASP Top 10 and OWASP API Security Top 10 — authentication, injection and fuzzing — ensuring compliance with enterprise security standards. • Own CI/CD pipeline strategy end to end in Azure DevOps: build, Nexus IQ security scanning and automated test execution on enterprise agents, published as a quality gate on every commit; defined entry and exit criteria and release-readiness reporting used for go/no-go decisions. • Architected a C# BDD validation platform (Reqnroll, RestSharp, Dapper, xUnit) covering REST API and Kafka event-driven flows as a reusable core library shared across squads, and a Python framework (pytest, pytest-bdd, PostgreSQL, AWS Redshift) whose allocation validation engine cut planogram checks from 3–4 hours for 4 products to under 2 minutes for 800+. • Designed and deployed a Datadog APM and RUM observability platform — P95 latency, error rate and database monitors with automated alerting and executive daily reporting; mentor engineers on BDD practice, test design and code review.	
AI Governance & Security — Independent Research and Tooling <i>Self-directed</i>	Oct 2025 – Feb 2026 Remote
• Built AI governance assessment methodology and tooling against the NIST AI RMF, ISO/IEC 42001 and EU AI Act risk tiers — control gap analysis, AI risk registers and prioritized, costed remediation roadmaps. • Developed an adversarial LLM security assessment suite covering eight categories of injection — direct and role-play prompt injection, instruction smuggling, indirect injection via retrieved data, prompt leaking, jailbreak, insecure output handling and data exfiltration — mapped to the OWASP Top 10 for LLM Applications and MITRE ATLAS, with formal PDF vulnerability reporting. • Engineered a DevSecOps pipeline gate integrating Semgrep static analysis with custom rules, software composition analysis and Trivy container scanning, failing builds on high and critical findings under a documented suppression policy. Completed structured coursework in MLSecOps, the NIST CSF and ISO/IEC 27001, applied directly to the tooling. All work published as open reference implementations.	
Sr. QA Engineering Consultant — Controls & Process Mapping <i>AdoptUSKids.org</i>	Jul 2025 – Sep 2025 Remote
• Mapped engineering and release processes to ISO 9000, ISO/IEC 27001 Annex A and NIST 800-53 control families, producing audit-ready control evidence and a prioritized remediation plan for leadership. • Conducted a quality function gap analysis for a ReactJS and microservices platform and delivered the resulting strategy — test planning, framework selection, CI/CD integration, reporting, security testing approach and a JMeter performance plan with an Azure DevOps roadmap.	

QA Manager / Sr. SDET Lead

Jul 2024 – Feb 2025

Word & Brown Companies — Healthcare Insurance Platform

Remote

- Managed onshore and offshore QA teams for a healthcare web platform serving health-insurance brokers — assigned coverage, reviewed test code, and presented QA metrics and release-readiness reporting to senior leadership.
- Led architecture of Page Object Model and data-driven C# frameworks (Reqnroll/Playwright, .NET Core) across UI, API and database layers; owned Azure DevOps pipelines for nightly regression as a standing quality gate and migrated legacy systems from TFS.
- Recommended security testing processes leveraging OWASP guidelines and automated vulnerability scanning for proactive risk mitigation.

Sr. SDET → Sr. Test Consultant

Feb 2022 – Jul 2024

Starbucks Coffee Company

Remote

- Owned end-to-end test strategy for an iPad application rollout spanning security, performance, functional and UX coverage, executed on secured browsers (Island, VMware Browser).
- Led QA strategy and automation for the Connect Platform (POS) with a SpecFlow/C# BDD framework that cut manual testing effort by 50% across a large retail estate; conducted API security testing for MFA authentication flows and reported release readiness to senior stakeholders.

Sr. Performance Engineer

Jun 2021 – Dec 2021

Premiera Blue Cross — Healthcare Claims

Remote

- Developed JMeter performance suites simulating 10,000+ concurrent users for healthcare claims processing; reduced API response times by 40% using Dynatrace, Splunk and New Relic for bottleneck identification.

SDET — Security Testing / Automation / Performance

Jul 2020 – May 2021

ReverseVision — Mortgage Lending Platform

Remote

- Performed API security assessments — authentication testing, injection, fuzzing, weak-password and boundary scans, and cross-site scripting — surfacing vulnerabilities for engineering remediation.

Sr. Automation Engineer / SDET

Oct 2016 – Jun 2020

CoStar Group

Austin, TX & Irvine, CA

- Automated test suites for Apartments.com and LoopNet (50M+ monthly visitors); reduced regression defects by 45% and mentored junior SDETs on framework architecture.

EARLIER EXPERIENCE

2010 – 2016 QA Manager / QA Lead / QA Project Manager — Word & Brown General Agency · Guthy | Renker · LA Fitness · Experian · Wells Fargo

Led QA teams of up to 12 engineers onshore and offshore across banking, credit, insurance and retail; implemented defect triage workflows, release quality gates and executive quality reporting, and delivered on regulated programmes including a state health insurance exchange (HIX).

SELECTED AI GOVERNANCE & SECURITY PROJECTS

Open reference implementations — github.com/sharingkapotter

- **EU AI Act Compliance Analyzer** — automated conformity assessment: risk-tier classification, scoring against mandatory requirements, gap analysis and a costed 12-month remediation roadmap, cross-mapped to NIST AI RMF functions.
- **LLM Security Assessment Suite** — eight-category adversarial injection harness against a deployed LLM assistant with severity scoring and PDF vulnerability reporting, mapped to OWASP LLM Top 10 and MITRE ATLAS.
- **DevSecOps Pipeline Gate** — GitHub Actions gate combining Sengrep SAST with custom rules, SCA and Trivy container scanning; complete fail → remediate → pass loop under a documented suppression policy.
- **Adversarial Attack Lab** — FGSM and PGD evasion against a ResNet18 classifier, demonstrating a shift from 77% correct to 100% confident and wrong, with countermeasure evaluation against EU AI Act Article 15 robustness requirements.
- **AI Risk Register & Incident Dashboard** — reusable risk register mapped to NIST AI RMF functions and EU AI Act obligations with scoring, ownership and residual-risk tracking, plus bias, explainability and safety metrics across the model lifecycle.

CERTIFICATIONS & PROFESSIONAL DEVELOPMENT

In progress IAPP AIGP — Artificial Intelligence Governance Professional · ISACA CRISC (planned)

AI & Security MLSecOps Foundation (Coursera) · ISO/IEC 27001 Information Security (Coursera) · NIST Cybersecurity Framework (Coursera) · Managing Cybersecurity — GRC (Coursera) · Ethical Hacking Fundamentals (Coursera) · SIEM & Event Management (LinkedIn Learning)

Delivery & Engineering Certified Scrum Master (Scrum Alliance) · ASTQB Foundation · ITIL Foundation · Python Foundations (University of Michigan) · Advanced JMeter

EDUCATION

Certificate, Global Management Operations — University of California, Irvine · Diploma, Computer Engineering — Boston Computer Institute, India · Bachelor of Commerce (Accounting & Finance) — University of Mumbai, India